

Firma Digitale: Strumento Matematico



I+A in TLS



- ❑ Integrità + Autenticazione Subject: proprietà associate alla **connessione TCP**
 - ❑ Solo **all'altra estremità** della connessione
 - ❑ Solo **durante esistenza** connessione

- ❑ In parole povere: proprietà verificabili
 - ❑ Solo da **una** entità
 - ❑ Solo per **poco tempo**

I+A ? (I)



- ❑ **File** costruito a T_0 da Subject-X
- ❑ Referto medico, Verbale esame, Programma eseguibile, ...
 - ❑ Ricevente lo preleva da memory pen
 - ❑ Ricevente lo scarica da un server con HTTPS
- ❑ **Email** costruito a T_0 da Subject-X
- ❑ Referto medico, Verbale esame, Programma eseguibile, ...
 - ❑ Ricevente scarica dalla propria mailbox con POP su TLS

I+A ? (II)



- ❑ File costruito a T_0 da Subject-X
 - ❑ Ricevente lo preleva da memory pen
 - ❑ TLS: non si usa
 - ❑ Ricevente lo scarica da un server con HTTPS
 - ❑ TLS: I+A rispetto a **prelievo da server**

- ❑ Email costruito a T_0 da Subject-X
 - ❑ Ricevente scarica dalla propria mailbox con POP su TLS
 - ❑ TLS: I+A rispetto a **prelievo da mail server**

- ❑ Ricevente **non** ha I+A rispetto a T_0 / Subject-X!!!

Obbiettivo



- ❑ Integrità + Autenticazione Subject su **"qualunque" canale di comunicazione**
 - ❑ Memory pen / Disco esterno
(senza limitazioni su come arrivi)
 - ❑ Prelievo da 1 server
(senza limitazioni sul protocollo: anche HTTP)
 - ❑ Passaggio da molti server
(senza limitazioni sui protocolli)
 - ❑ ...

- ❑ In parole povere: proprietà verificabili
 - ❑ Da **qualunque** entità
 - ❑ In qualunque momento (anche **"dopo moltissimo tempo"**)

Obiettivo:

Altro punto di vista

- ❑ Subject-A crea sequenza di byte **B**
- ❑ Non indirizzata a **nessun** Subject specifico
- ❑ **B** spostata nello **spazio** e nel **tempo**
 - ❑ Transita tra molti server
 - ❑ Inserita in memory pen inviata per corriere
 - ❑ Inserita in CD archiviato
 - ❑ ...
- ❑ Dopo **mesi / anni**,
chiunque può verificare **autenticità** ed **integrità** di **B**
- ❑ **Indipendentemente** dal percorso spazio/tempo di **B**



Premessa



- ❑ Non vediamo cosa c'è dentro
- ❑ Crittografia a chiave pubblica + "altro"

Scenario di partenza

KPUB-X



KPUB-X



KPUB-X



Chiave pubblica
già distribuita



KPRIV-X



KPUB-X

Scenario di arrivo

KPUB-X



**VERIFICA
FIRMA**

KPUB-X



**VERIFICA
FIRMA**

KPUB-X



**VERIFICA
FIRMA**



KPRIV-X



KPUB-X

**COSTRUZIONE
FIRMA**

Firma Digitale: Costruzione

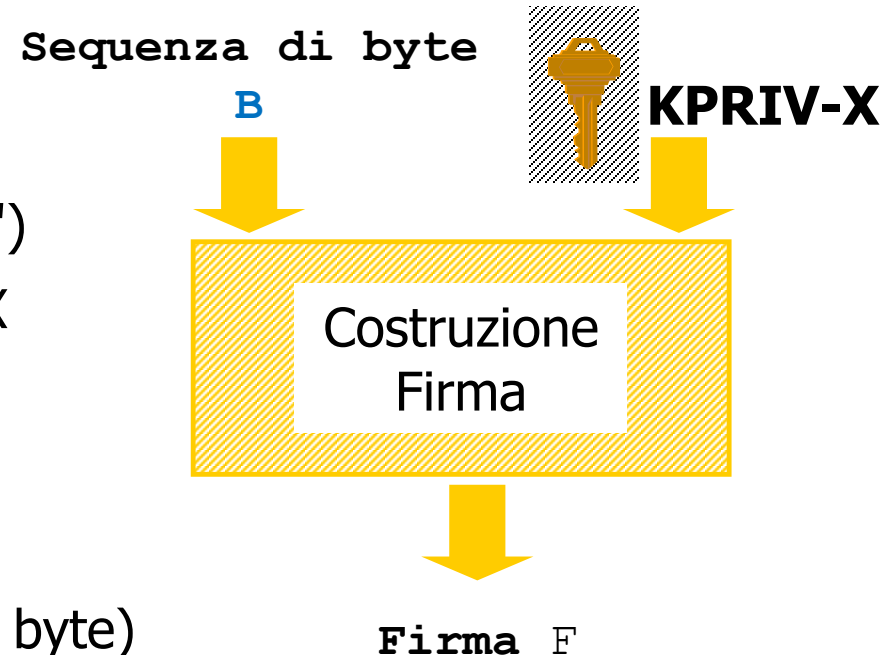
- Sequenza di byte F ("firma digitale")

- Valore dipendente da B , K_{PRIV-X}

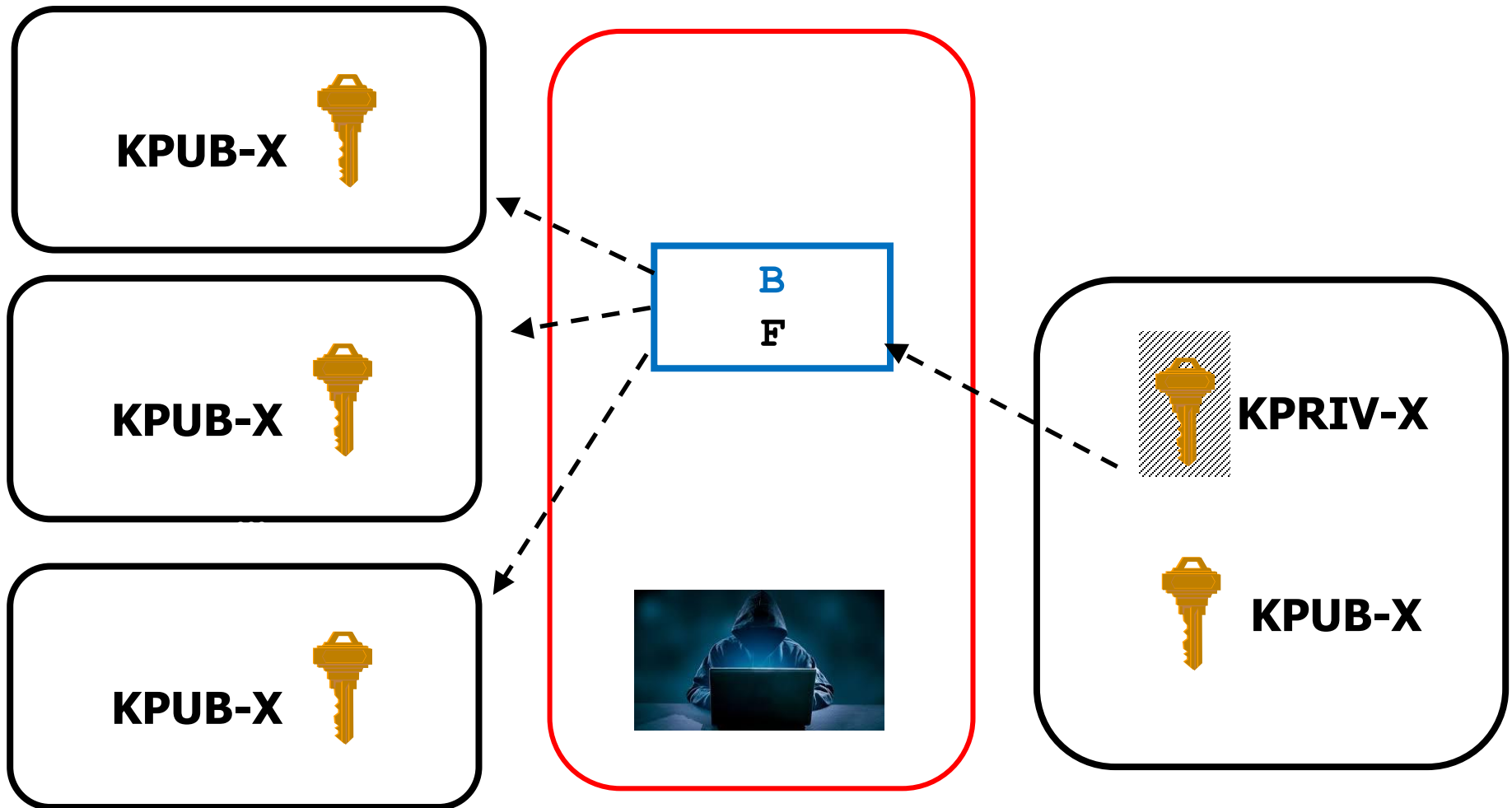
$$F := \text{Sign}_{K_{PRIV-X}}(B)$$

- Lunghezza **costante** (tipico 128 byte)

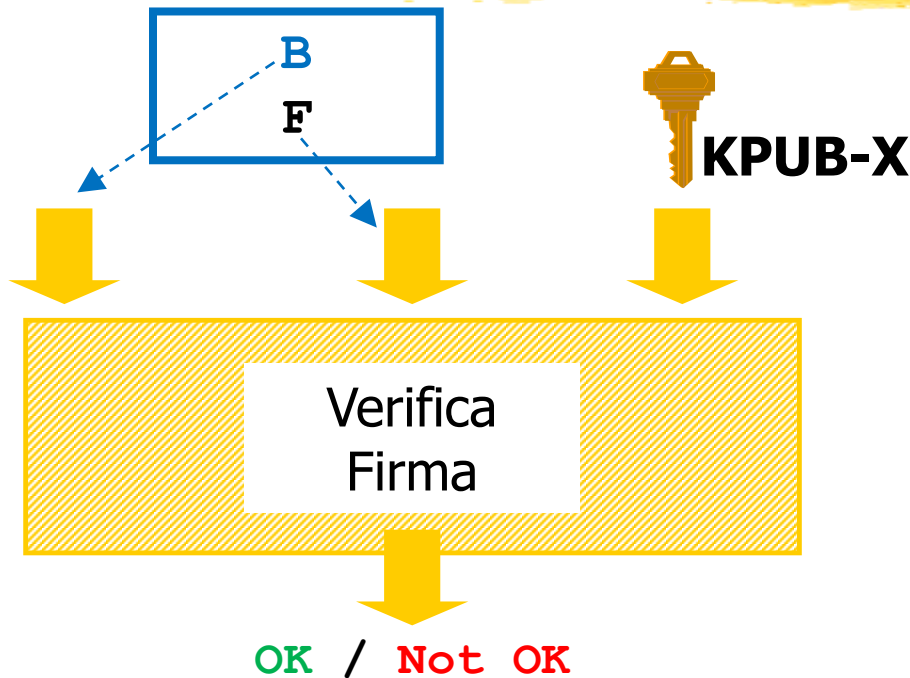
- Numero firme possibili: $2^{(128 \cdot 8)}$



B viaggia nel tempo / spazio



Firma Digitale: Verifica



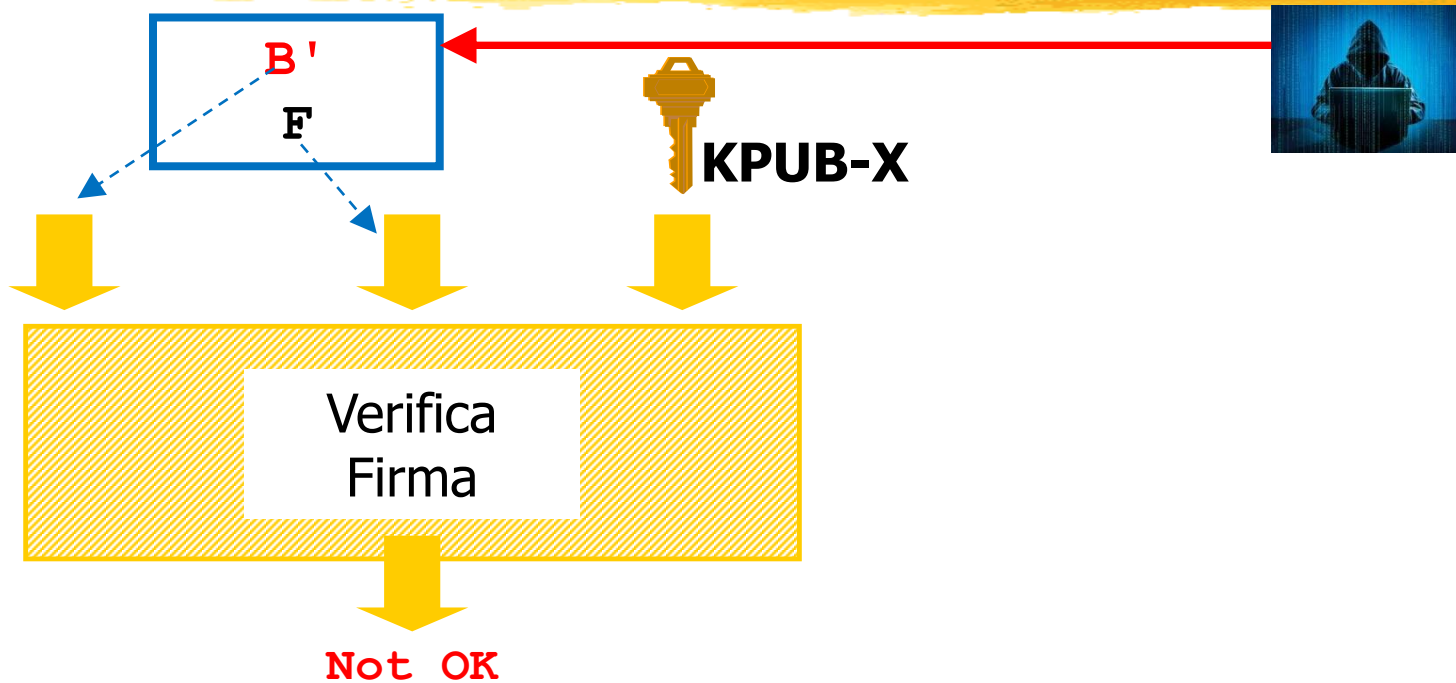
OK $\Rightarrow$

- ☐ F generata da K_{PRIV-A} per B (autenticità)
- ☐ Neanche un bit alterato in B, F (integrità)

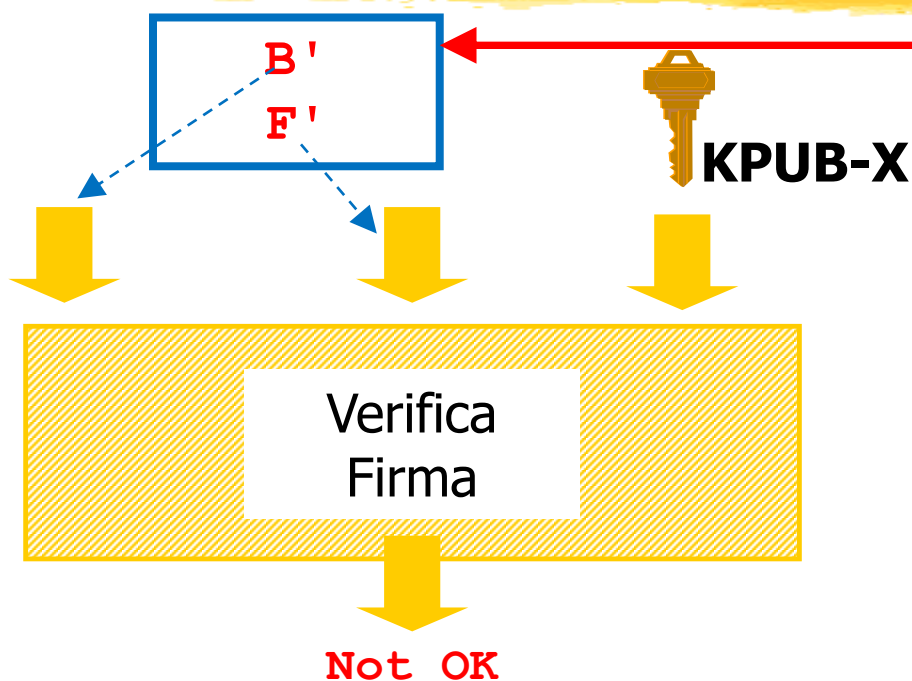
Not OK $\Rightarrow$

- ☐ F **non** generata da K_{PRIV-A} per B oppure
- ☐ **Alterato** almeno un bit in B, F

Integrità

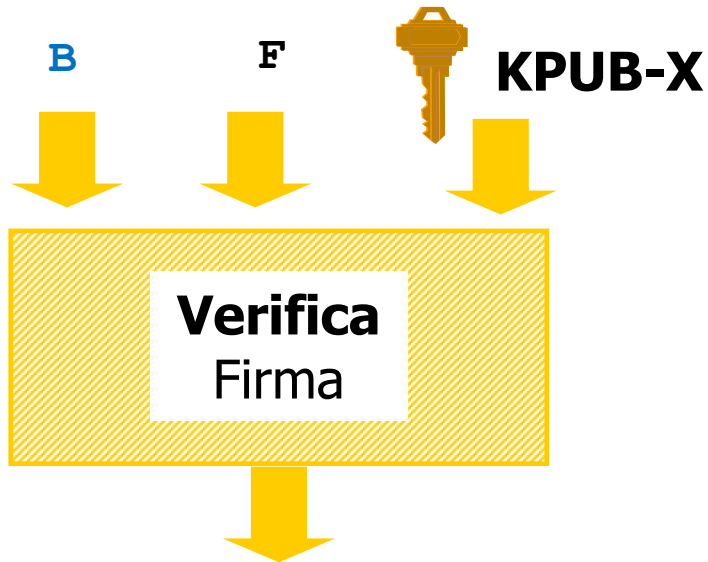


Autenticazione

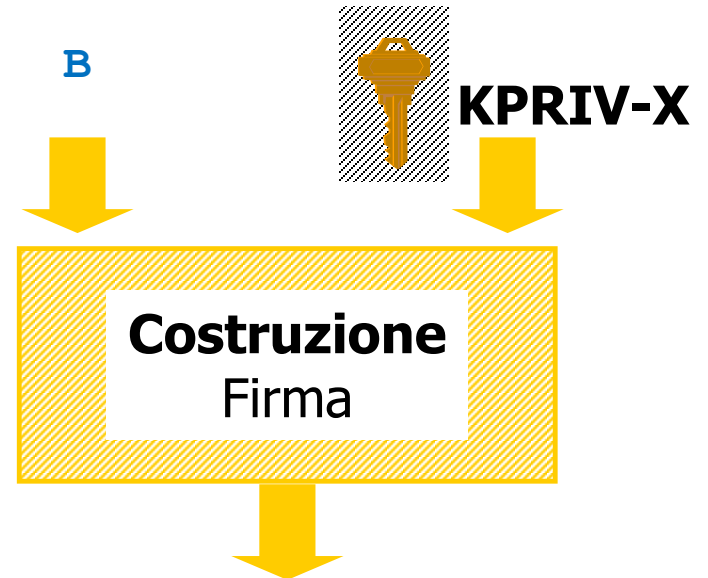


- ❑ Calcolare $F' = \text{Sign}_{K_{PRIV-X}}(B')$ senza K_{PRIV-X} è "praticamente impossibile"
- ❑ *"Senza la chiave privata non posso firmare"*

Osservazione 1

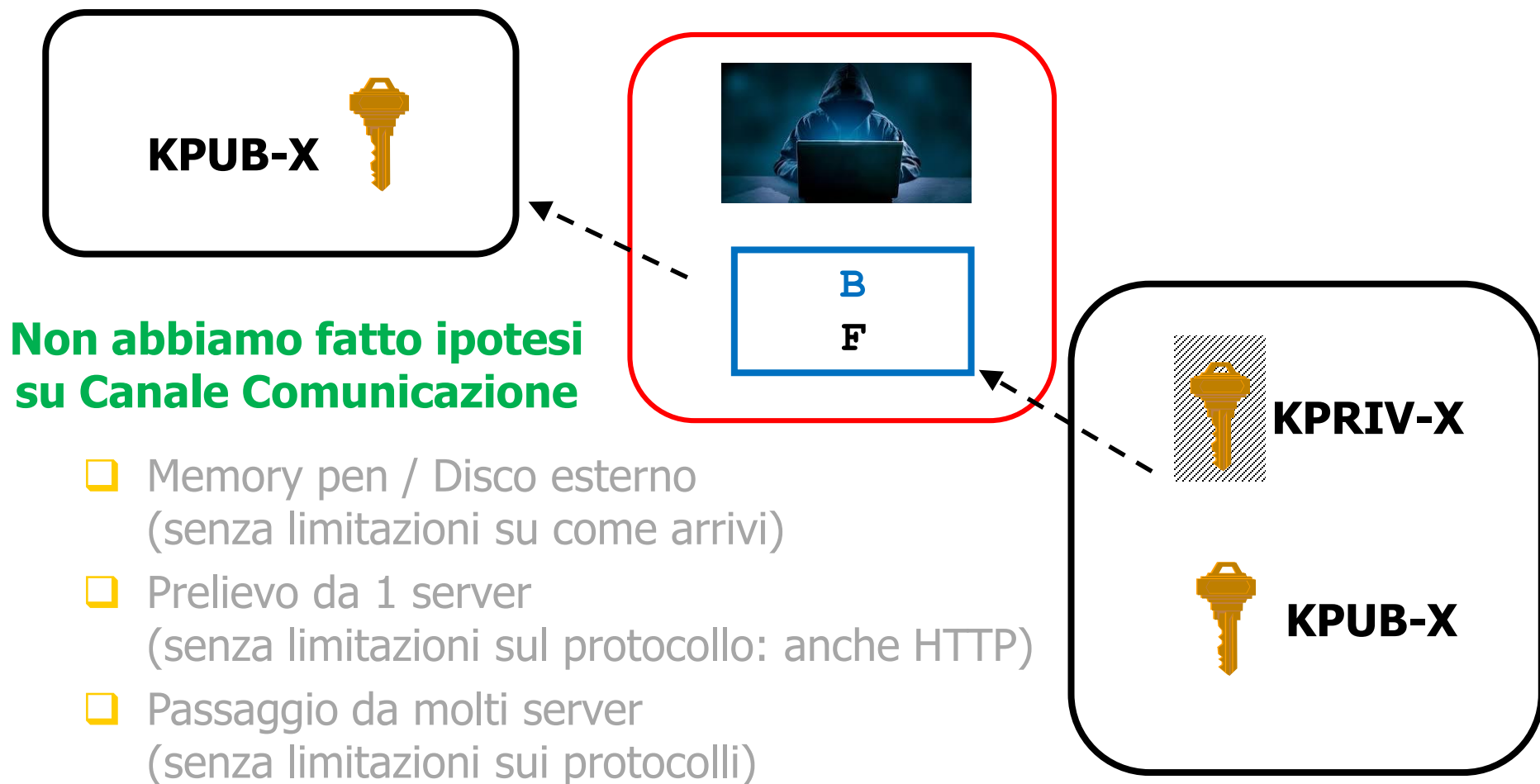


☐ Può farla **chiunque**

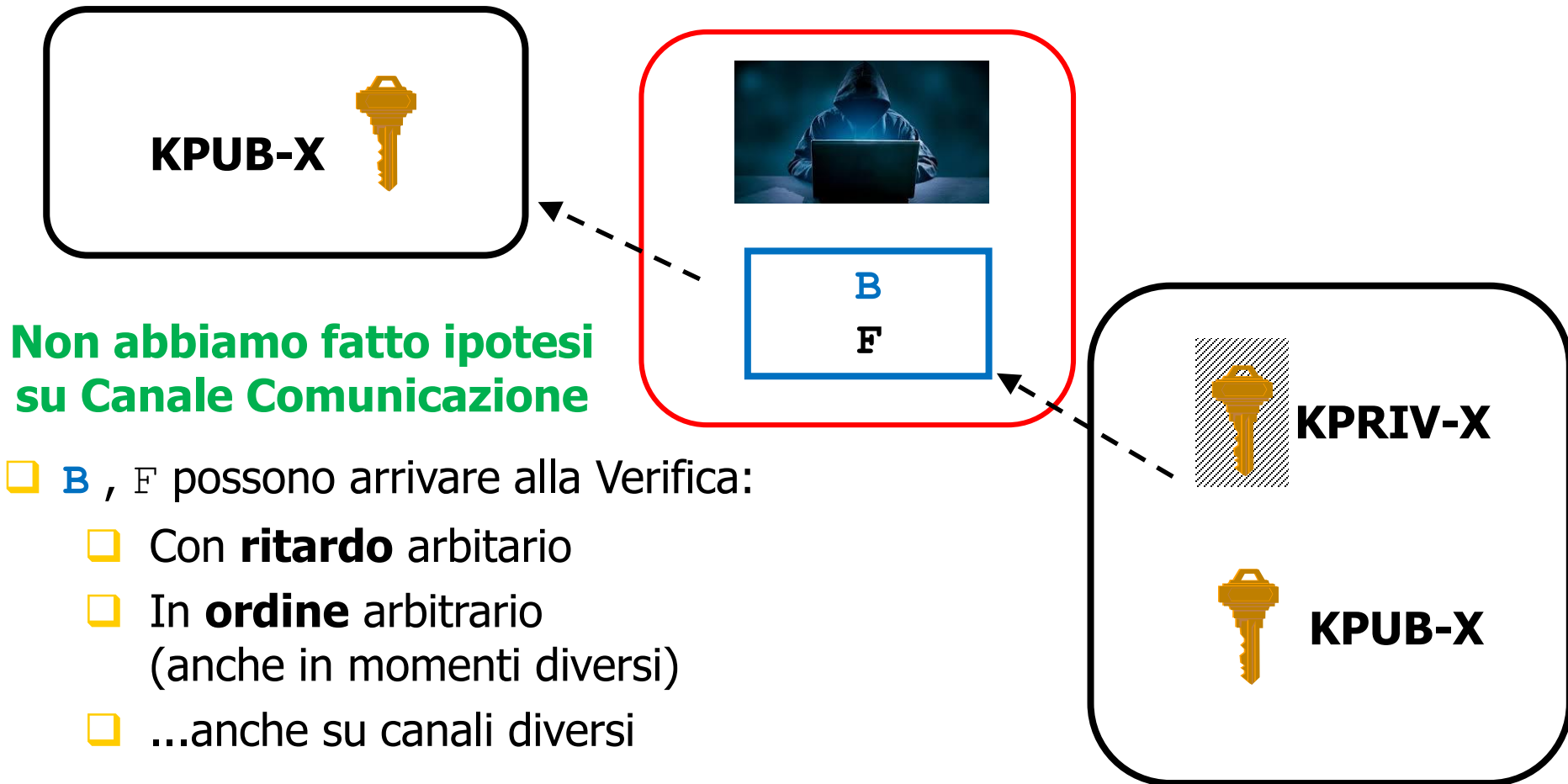


☐ Può farla **solo** chi conosce KPRIV-X

Osservazione 2 (I)



Osservazione 2 (II)



Non ci siamo ancora...



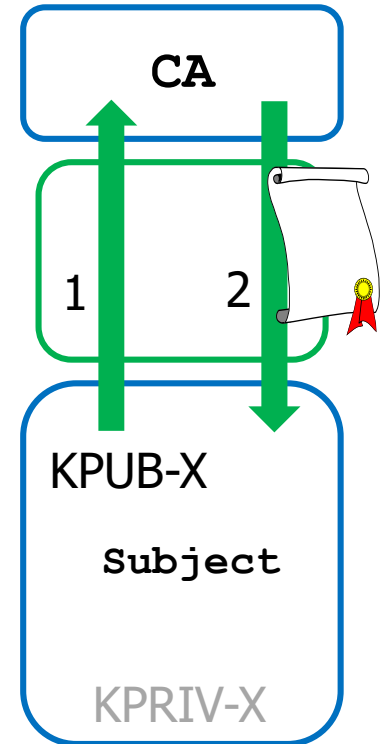
OK $\Rightarrow$

- ☐ F generata da KPRIV-A per B
(autenticità)
- ☐ Neanche un bit alterato in B , F
(integrità)
- ☐ Integrità + Autenticazione Subject su **"qualunque" canale di comunicazione**
- ☐ Abbiamo autenticazione di **KPRIV-A**
- ☐ Vogliamo autenticazione di **Subject-A**
- ☐ Dobbiamo introdurre i **certificati**

Firma Digitale: Strumento applicativo

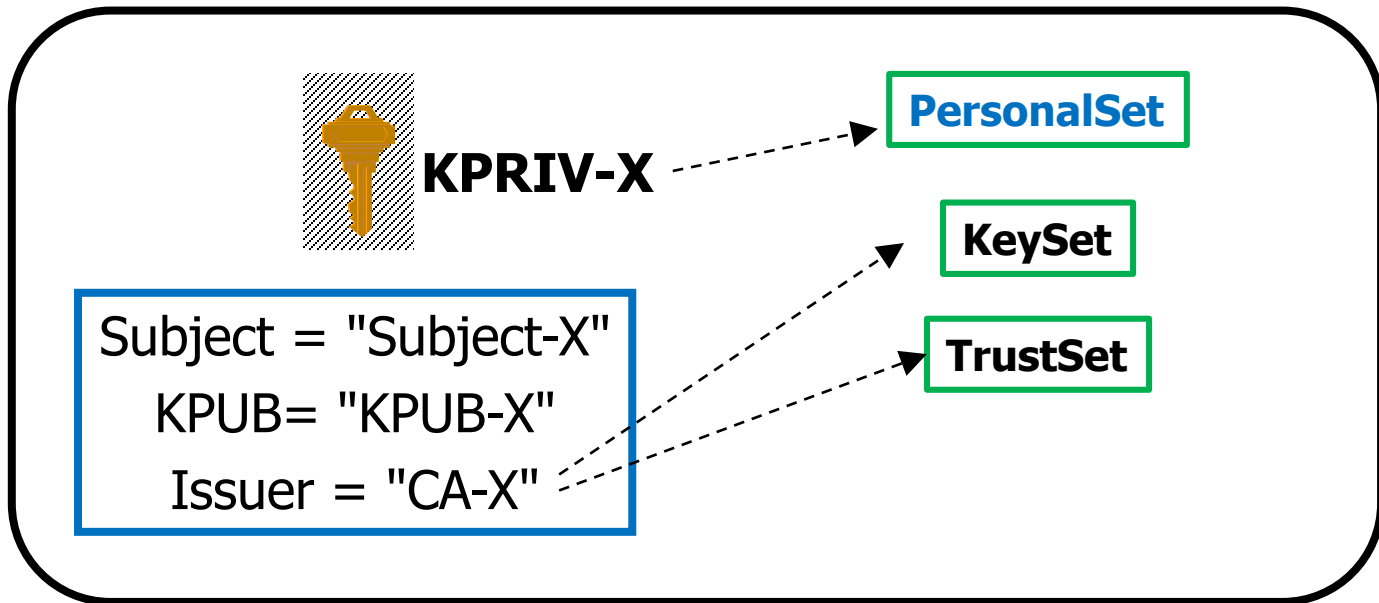


Scenario di partenza (I)

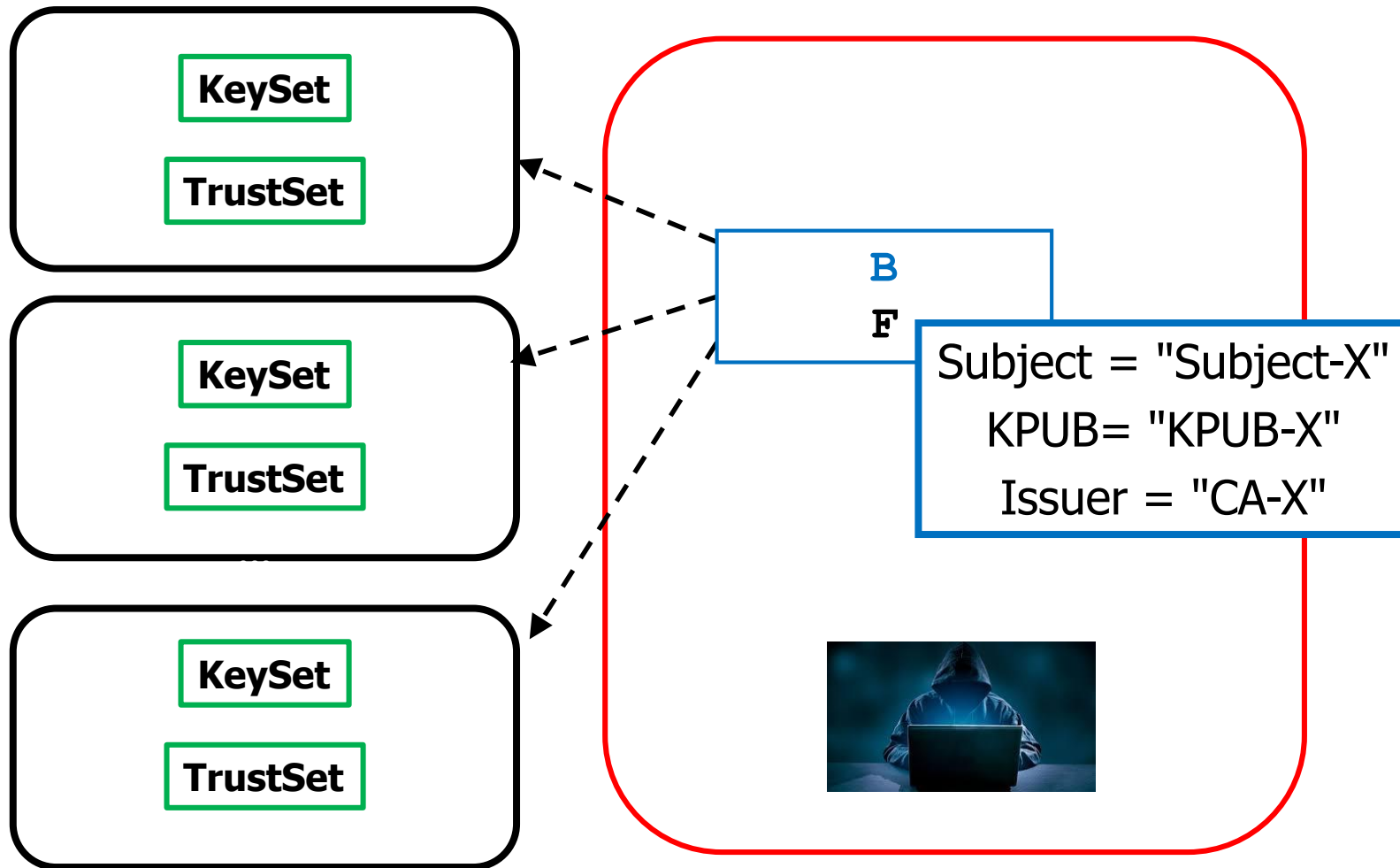


- ❑ I Subject che si devono autenticare **"firmare"** hanno:
 - ❑ (K-PRIV,K-PUB)
 - ❑ Certificato
- ❑ Nostra semplificazione: **solo i-Server**
i Subject che devono firmare

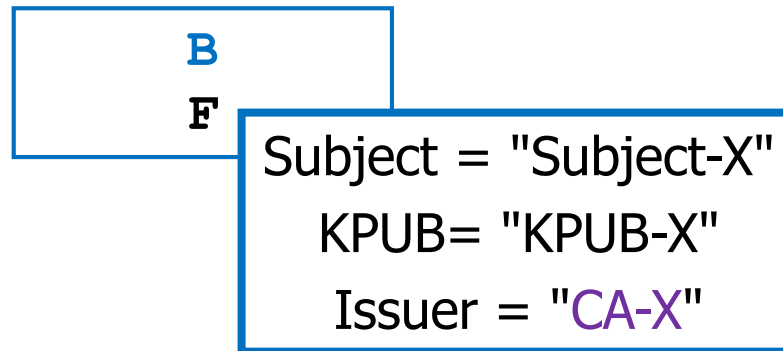
Scenario di partenza (II)



B viaggia nel tempo / spazio

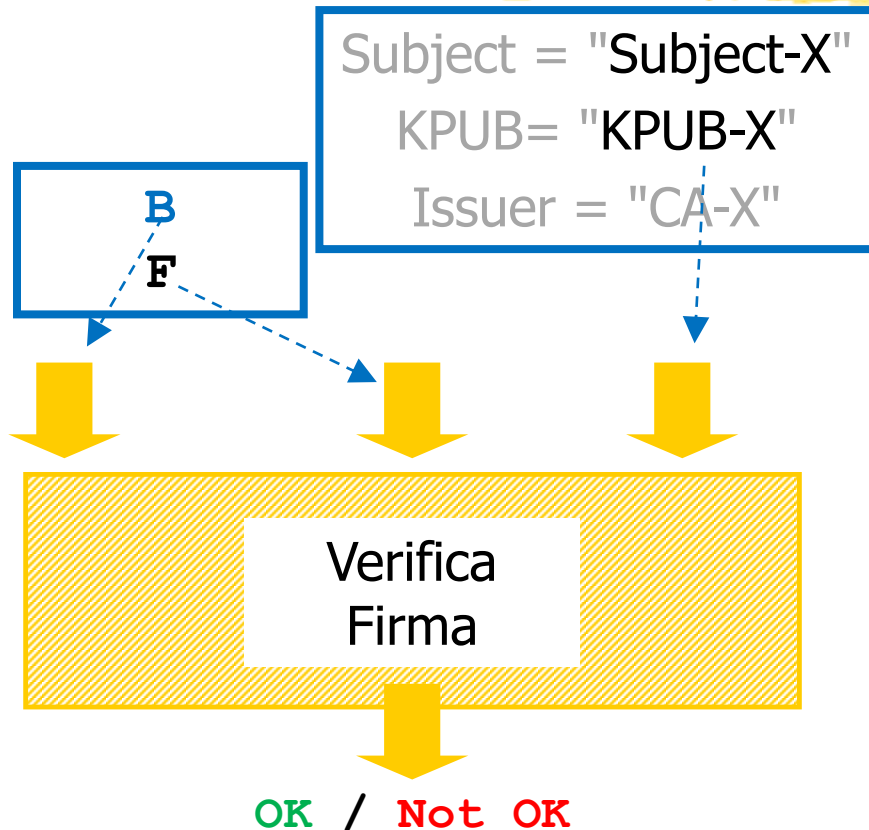


Firma Digitale: Verifica (I)



1. Verifica **certificato**
 1. CA-X $\in$ TrustSet
 2. CA-Y $\in$ KeySet
 3. CERT è autentico e integro
2. **Verifica firma** <B, F, CERT.KPUB>

Firma Digitale: Verifica (II)



OK $\Rightarrow$

- ☐ F generata da Subject-X per B (autenticità)
- ☐ Neanche un bit alterato in B, F (integrità)

Not OK $\Rightarrow$

- ☐ F **non** generata da Subject-X per B
oppure
- ☐ **Alterato** almeno un bit in B, F

FANTASTICO (REMINO)

- ❑ Subject-A crea sequenza di byte **B**
- ❑ Non indirizzata a **nessun** Subject specifico
- ❑ **B** spostata nello **spazio** e nel **tempo**
 - ❑ Transita tra molti server
 - ❑ Inserita in memory pen inviata per corriere
 - ❑ Inserita in CD archiviato
 - ❑ ...
- ❑ Dopo **mesi / anni**,
chiunque può verificare **autenticità** ed **integrità** di **B**
- ❑ **Indipendentemente** dal percorso spazio/tempo di **B**



Cert valido + Verifica Firma OK

B

F

Subject= 5943

KPUB = KPUB-E

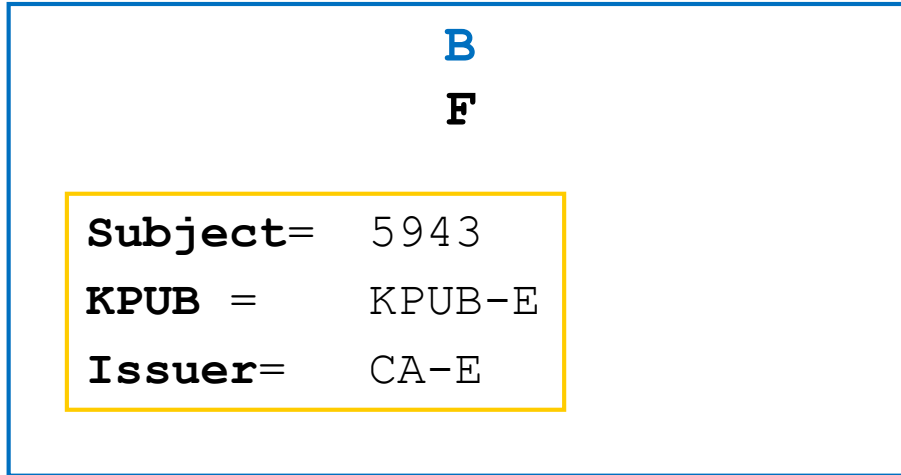
Issuer= CA-E

- CA-E **ha accertato** che SubjectFisico identificato da 5943 è associato a KPUB-E

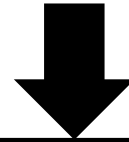


- F costruita per B da SubjectFisico che controlla 5943 + integrità

Cert **NON** valido + Verifica OK



- ❑ CA-E **NON** ha accertato che SubjectFisico identificato da 5943 è associato a KPUB-E



- ❑ F costruita per B da SubjectFisico che conosce KPRIV-E + integrità

- ❑ Nessuna garanzia su "chi è" il SubjectFisico

Firma Digitale:

In pratica

A horizontal yellow brushstroke with a textured, painterly appearance, extending across the width of the slide below the title.

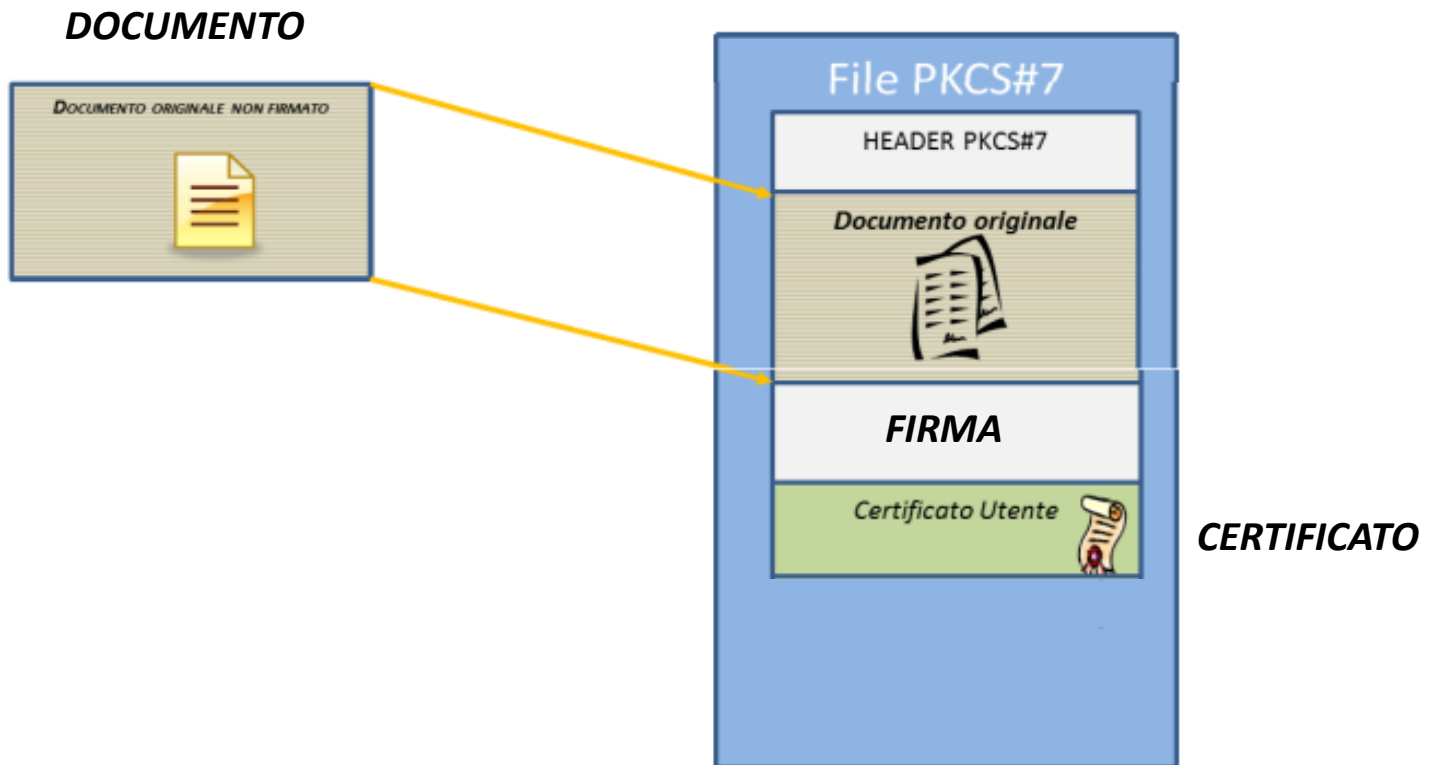
Formato file firmato



- ❑ Spesso **concatenati** in una **unica** sequenza di byte:
 - ❑ Documento `B`
 - ❑ Firma `F`
 - ❑ Certificato del Subject che ha firmato `cert`

- ❑ Necessari **standard** per descrivere la struttura della sequenza
 - ❑ PKCS7
 - ❑ PKCS12
 - ❑ p7m
 - ❑ ...

Esempio



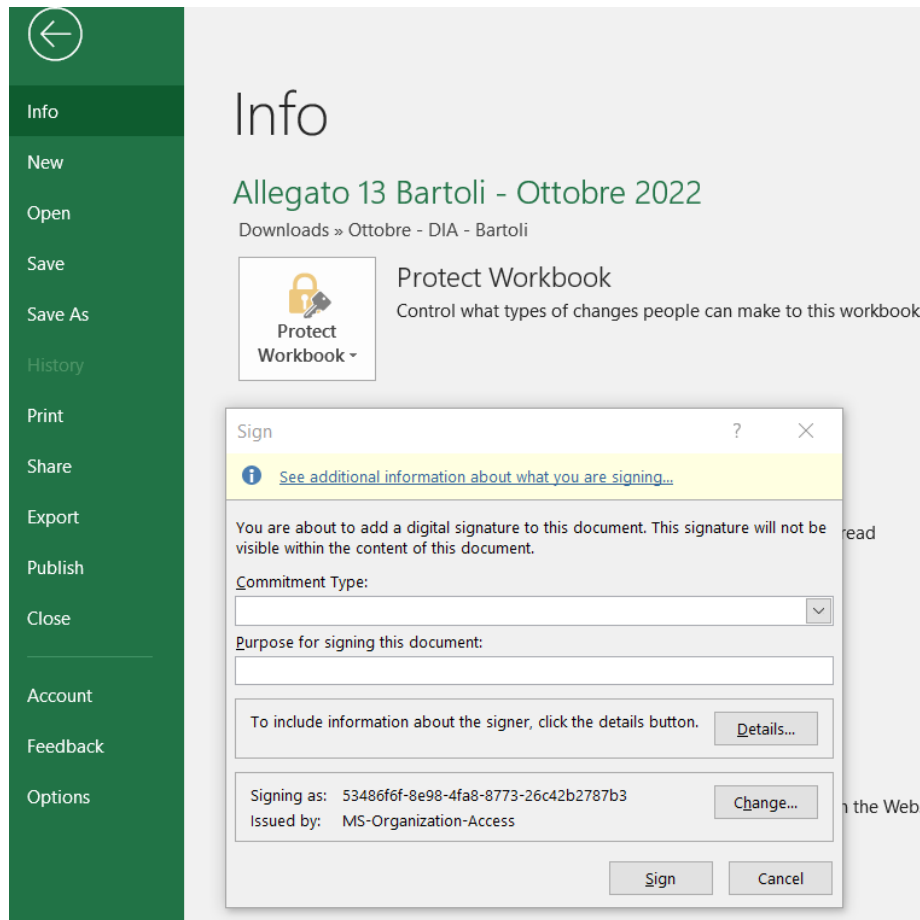
Firma e Verifica



- ❑ Funzionalità integrate in **programmi non specifici**
 - ❑ Word, Excel, PDF readers, ...
 - ❑ Documento + Firma + Certificato in **unico file**
 - ❑ Firma: accesso a PersonalSet
 - ❑ Verifica: accesso a KeySet / TrustSet

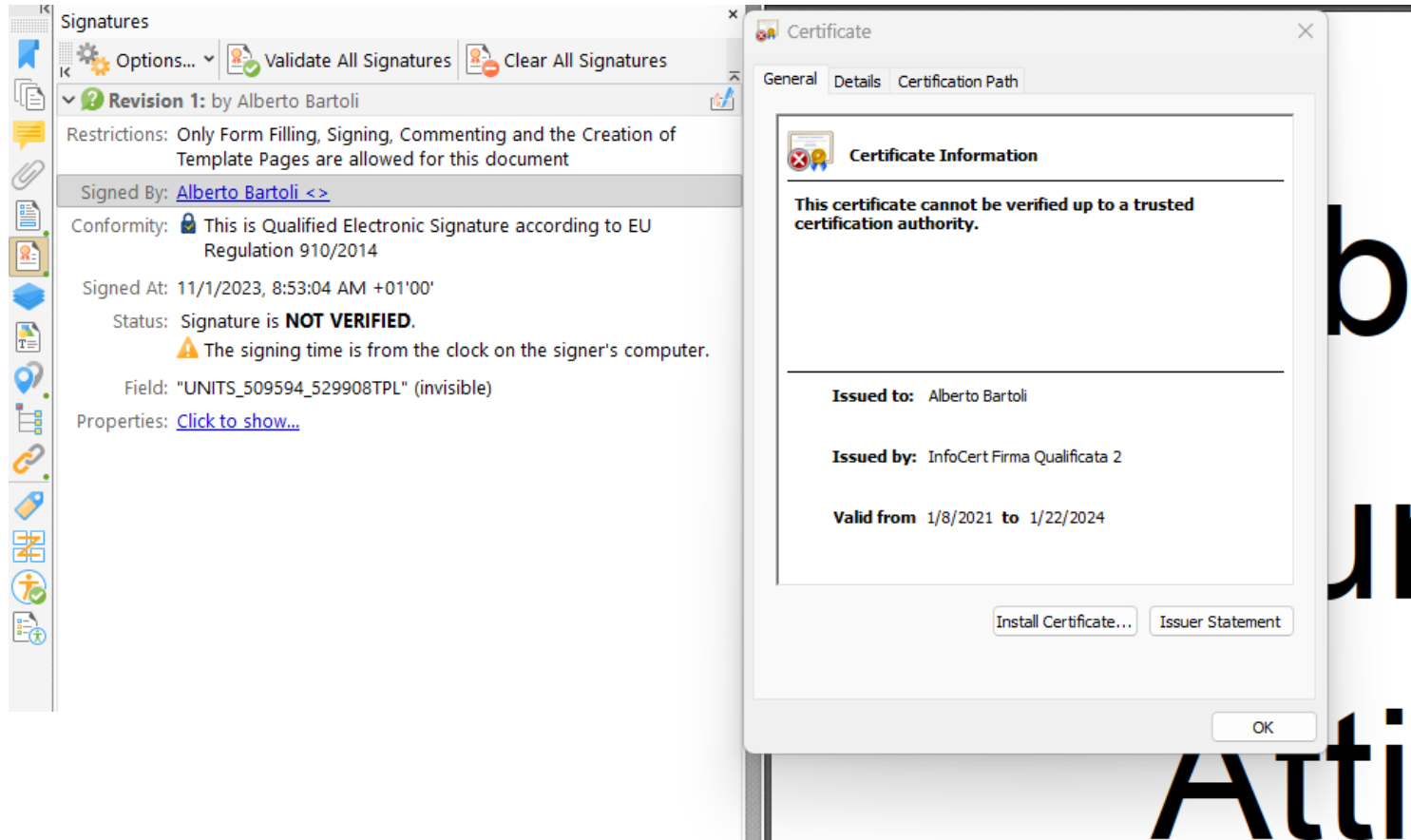
- ❑ Funzionalità di **programmi specifici**
 - ❑ OpenSSL, GnuPG, ...
 - ❑ **Moltissime** varianti per file con Documento, Firma, Certificato

Esempio (I): Programma non specifico

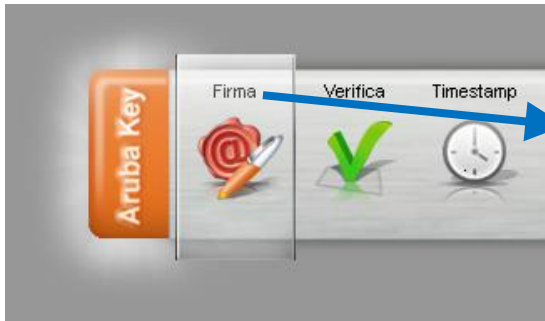


Microsoft Excel

Esempio (II): Programma non specifico



Esempio: Programma specifico



Accede al mio
PersonalSet
(sbloccato da un "pin")

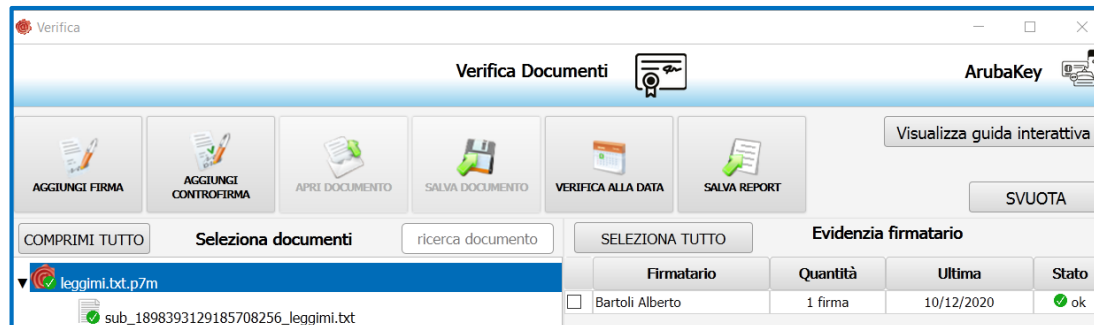
The screenshot shows the 'Firma - leggi.txt' window. The title bar indicates the file being signed is 'leggi.txt'. The main heading is 'Firma del file', with a sub-instruction: 'Selezionare il certificato. Se il certificato è a validità legale è necessario esaminare il documento per poter effettuare la firma'. Below this, there is a section 'Seleziona il certificato:' with a dropdown menu showing 'Bartoli Alberto' and a 'Dettagli...' button. A 'PIN' field is highlighted with a blue box, with the label 'Inserisci il PIN:'. Below the PIN field is a 'Salva come:' section with a text box containing the file path 'C:\New-MyCloud\Google Drive\Work\Didattica\Reti di Calcolatori I\2020\leggi.txt.p7m' and a blue button. There are checkboxes for 'Distruggi il documento originale al termine della firma' and 'Richiedi timestamp'. Below these are dropdown menus for 'Tipologia di firma' (set to 'Busta crittografica P7M (CAES)') and 'Formato .TSD (con firma in allegato)'. The 'Aruba Key' logo is at the bottom left. At the bottom right are buttons for '< Back', 'Next >', and 'Cancel'.

Osservazione

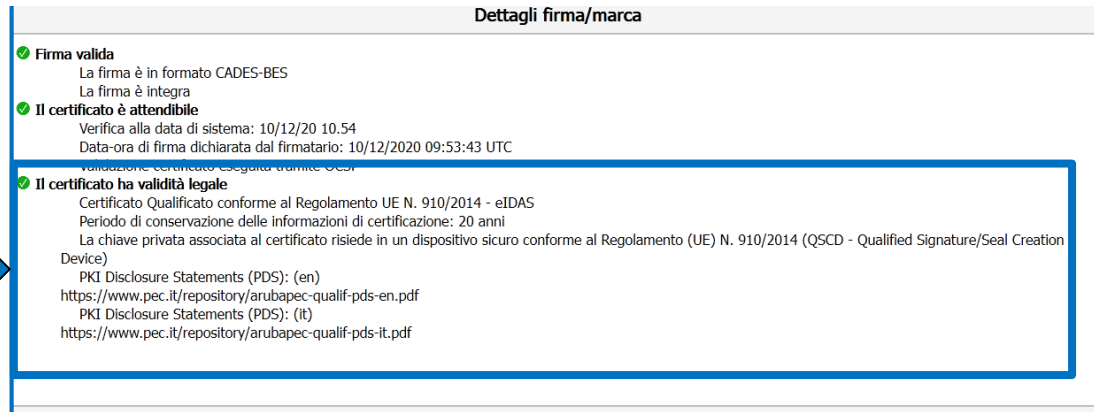


- ❑ Gergo comunissimo: *Firma **con il certificato***
- ❑ SBAGLIATISSIMO: Confonde le idee
- ❑ Si firma **con la chiave privata** !!!

"Validità legale"



- ❑ Norme su algoritmi, CA, distribuzione e **revoca** delle chiavi,...
- ❑ Non vediamo



Osservazione



- ❑ Gergo comunissimo: ***Acquisto / Ho la firma digitale***
- ❑ SBAGLIATISSIMO: Non esiste "la" firma digitale (quindi non si può comprarla)
- ❑ Si acquistano chiavi + certificati per costruire firme digitali con validità legale

Applicazione importantissima (I)

❑ Software eseguibile

- ❑ Smartphone apps
- ❑ Aggiornamenti sistemi operativi / applicazioni
- ❑ Librerie
- ❑ ...

❑ **Numerosi step** da sviluppatore a dispositivo su cui è installato

- ❑ Immaginate cosa potrebbe fare un network attacker...
- ❑ ...o un attacker che riesce ad operare su server "di passaggio" o "di download"

Applicazione importantissima (II)

- ❑ Nei sistemi operativi più diffusi:
 - ❑ Software eseguibili devono essere **firmati**
 - ❑ Firma costruita da
 - ❑ Sviluppatoreoppure
 - ❑ Gestore dello "app marketplace"
- ❑ Procedura di installazione:
 1. Verifica (certificato e) firma
 2. Installa solo se Subject è in una lista predefinita (sviluppatori / gestori autorizzati)

Firma Digitale: Capiamo bene



Cosa significa "autentico e integro" (I)

❑ Non significa "vero"

- ❑ «*Gli asini volano*»
(affermazione certamente falsa)
- ❑ Può essere firmata da una KPRIV-X
- ❑ Verifica con KPUB-X ha successo $\Rightarrow$ Autentico e Integro

- ❑ «*Dio esiste*» e «*Dio non esiste*»
(una delle affermazioni è certamente falsa)
- ❑ Ognuna può essere firmata da una KPRIV-X
- ❑ Verifica di ognuna con KPUB-X ha successo $\Rightarrow$ Autentico e Integro

Cosa significa "autentico e integro" (II)



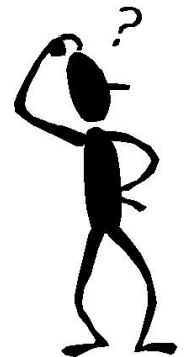
☐ Significa **solo** "Autentico e Integro"

- ☐ File Eseguiibile firmato
 - ☐ Verifica firma ha successo
 - ☐ Può contenere malware
 - ☐ Può avere bug
- ☐ File Eseguiibile non firmato
 - ☐ Può essere benigno
 - ☐ Può essere bug free

Esempio importante

- ❑ File PDF:
 - ❑ Descrizione di un referto medico
 - ❑ Generato ad istante $T = \text{"14/11/2022 ore 17.00"}$
- ❑ Firmato allo stesso istante T
- ❑ Verifica della firma ha successo

- ❑ Il referto medico è stato veramente generato a T ?
- ❑ Il file è stato veramente firmato a T ?



TLS vs Firma Digitale (I)



- ❑ Browser preleva un documento D che **non ha** firma digitale
- ❑ D ha URL HTTPS
 - ❑ Quanti messaggi sono firmati dal browser?
 - ❑ Quanti messaggi sono firmati dal web server?

TLS vs Firma Digitale (II)



- ❑ Browser preleva un documento D che **ha** firma digitale
- ❑ D ha URL HTTPS
 - ❑ Quanti messaggi sono firmati dal browser?
 - ❑ Quanti messaggi sono firmati dal web server?